



Debate Académico 2

Oscar Chavarría Hernández

Universidad CENFOTEC

CIB-12 SEGURIDAD EN REDES

Profesor: MARCIAL IGNACIO HERNANDEZ VILLALOBOS

2025

Análisis y Aplicación de Cortafuegos y Normas de Ciberseguridad en Redes según los CIS Controls v8

1. Análisis del Problema

La transmisión de datos es el proceso por el cual la información se mueve entre dispositivos mediante redes públicas o privadas. En redes públicas, como las Wi-Fi gratuitas en lugares públicos, esta información generalmente no está bien protegida, lo que facilita que atacantes puedan interceptar datos sensibles mediante técnicas como el *sniffing* o incluso realizar ataques man-in-the-middle, donde se intercepta y manipula la comunicación sin que los usuarios lo noten.

En redes privadas, como las de una empresa, si no se realiza una correcta segmentación que divida la red en zonas seguras, un atacante que ingrese a un dispositivo puede moverse libremente por toda la red, aprovechando el llamado movimiento lateral, lo que agrava el impacto de un ataque inicial.

En nuestra organización, que combina infraestructura local y servicios en la nube, hemos identificado varias vulnerabilidades críticas: un aumento de intentos de acceso no autorizados, reglas mal configuradas en el cortafuegos perimetral que podrían dejar abiertas rutas de acceso, y poca capacidad para detectar y responder rápidamente ante incidentes de seguridad. Estas debilidades suelen presentarse en redes mal segmentadas o con configuraciones deficientes en sus dispositivos de seguridad, poniendo en riesgo la protección de la información y la continuidad operativa.

2. Propuesta Técnica Basada en los CIS Controls v8

Para enfrentar todos estos problemas de seguridad, vamos a aplicar controles del marco CIS Controls versión 8. Este marco es como una guía clara y organizada de lo que una empresa debe hacer para protegerse contra ciberataques. No son leyes, pero sí son las mejores prácticas reconocidas a nivel mundial, creadas por expertos en ciberseguridad. Su objetivo es reducir riesgos, proteger los datos y asegurar que todo funcione bien, incluso en entornos complejos como redes internas, la nube o sistemas híbridos. En pocas palabras, si una empresa quiere tomarse en serio la seguridad, tiene que empezar por aquí.:

Control 4.1 – Configurar bien los dispositivos de red

Aplicación técnica:

- Revisar y actualizar la configuración por defecto de routers, switches y cortafuegos para desactivar servicios innecesarios (como Telnet, que es inseguro).

- Configurar listas de control de acceso (ACLs) en cada dispositivo para permitir solo el tráfico esencial según puertos, direcciones IP y protocolos.
- Habilitar registros de eventos para auditar accesos y cambios en los dispositivos.
- Automatizar la gestión de configuraciones con herramientas (como Ansible o scripts) para asegurar uniformidad y facilitar auditorías.

Aplicación estratégica:

- Establecer políticas de configuración estándar para todos los dispositivos de red, documentadas y aprobadas.
- Capacitar al equipo de redes y seguridad en mejores prácticas para la configuración segura.
- Realizar auditorías periódicas para detectar configuraciones incorrectas o desviaciones.
- Mantener un ciclo de actualización y parcheo para que los dispositivos no queden expuestos a vulnerabilidades conocidas.

Control 6.3 – Cuidar las cuentas con poderes especiales

Aplicación técnica:

- Implementar doble factor de autenticación (2FA) para accesos administrativos, usando apps de autenticación o tokens físicos.
- Crear y usar cuentas separadas para administración, diferenciando accesos de rutina de accesos críticos.
- Registrar todas las acciones realizadas por cuentas privilegiadas mediante sistemas de auditoría.
- Establecer controles de sesión, desconectando automáticamente tras periodos de inactividad.

Aplicación estratégica:

- Definir una política clara de gestión de cuentas privilegiadas, aprobada por la gerencia.
- Entrenar a usuarios privilegiados sobre riesgos y mejores prácticas de seguridad.
- Revisar regularmente los accesos y privilegios asignados, revocando los innecesarios.

- Incluir revisiones de cuentas privilegiadas en auditorías internas y externas.

Control 8.7 – Vigilar todo desde un solo lugar (SIEM)

Aplicación técnica:

- Desplegar un sistema SIEM que recoja logs de todos los dispositivos, servidores y aplicaciones críticas.
- Configurar reglas y alertas para detectar actividades inusuales, como múltiples intentos fallidos o accesos fuera de horario.
- Integrar fuentes de datos diversas para tener visibilidad completa (firewalls, sistemas antivirus, control de acceso, etc.).
- Automatizar la correlación de eventos para reducir falsas alarmas y priorizar incidentes reales.

Aplicación estratégica:

- Definir los casos de uso prioritarios para monitoreo y respuesta ante incidentes.
- Capacitar al equipo de seguridad en interpretación de alertas y manejo del SIEM.
- Establecer un proceso formal de respuesta ante incidentes basado en las alertas del SIEM.
- Revisar y actualizar periódicamente las reglas y casos de alerta según la evolución de amenazas.

Control 13.1 – Dividir para proteger (segmentación de red)

Aplicación técnica:

- Configurar VLANs para separar segmentos de red: usuarios, servidores, nube y DMZ.
- Aplicar reglas de firewall internas entre segmentos para controlar el tráfico permitido.
- Utilizar sistemas de autenticación y autorización para cada segmento, asegurando que solo usuarios autorizados accedan a cada “zona”.
- Monitorizar el tráfico entre segmentos para detectar movimientos laterales sospechosos.

Aplicación estratégica:

- Diseñar una arquitectura de red basada en la segmentación como principio básico de seguridad.
- Documentar claramente qué sistemas y usuarios pertenecen a cada segmento.
- Realizar pruebas y auditorías para validar que la segmentación se mantiene efectiva.
- Educar a los usuarios sobre la importancia de la segmentación y el acceso limitado.

Control 7.1 – Saber qué software está corriendo**Aplicación técnica:**

- Mantener un inventario actualizado y automatizado de todo el software instalado en los dispositivos.
- Implementar políticas que permitan instalar solo software aprobado y confiable (listas blancas).
- Usar herramientas de gestión de activos para detectar software no autorizado o potencialmente dañino.
- Realizar escaneos periódicos para validar el estado del software y detectar anomalías.

Aplicación estratégica:

- Definir políticas claras de uso y aprobación de software en la organización.
- Capacitar a los empleados sobre riesgos de software no autorizado o malicioso.
- Incluir la gestión de software en las auditorías regulares de seguridad.
- Establecer procesos para responder rápidamente cuando se detecta software no autorizado.

Control 12.4 – Detectar y corregir vulnerabilidades**Aplicación técnica:**

- Implementar escáneres de vulnerabilidades que analicen los sistemas y aplicaciones en busca de fallas conocidas.

- Establecer un proceso para priorizar, aplicar parches o mitigaciones según el riesgo.
- Automatizar actualizaciones cuando sea posible para acelerar la corrección.
- Verificar periódicamente que los parches se hayan aplicado correctamente.

Aplicación estratégica:

- Crear un programa formal de gestión de vulnerabilidades con roles y responsabilidades definidos.
- Informar a la dirección sobre riesgos críticos y planes de mitigación.
- Realizar campañas de concienciación sobre la importancia de mantener los sistemas actualizados.
- Integrar la gestión de vulnerabilidades con auditorías y revisiones de seguridad.

3. Implementación del Cortafuegos

Usaremos un **cortafuegos de próxima generación (NGFW)**, que no solo ve qué puerto o protocolo se usa, sino que “entiende” las aplicaciones, permitiendo reglas mucho más precisas y detectando tráfico sospechoso incluso en protocolos comunes.

Las reglas básicas que aplicaremos son:

- Solo dejar pasar el tráfico estrictamente necesario, según puerto, IP y protocolo:

Esto significa configurar el cortafuegos para que solo deje pasar las conexiones que son indispensables para el funcionamiento de la red. Por ejemplo, permitir tráfico HTTP (puerto 80) y HTTPS (puerto 443) hacia el servidor web, o permitir el acceso solo desde ciertas direcciones IP confiables.

¿Cómo? Se crean reglas específicas que definan qué puertos y protocolos están permitidos, y desde qué IPs o rangos de IPs.

- Bloquear todo lo que no esté autorizado (política “deny all”) :

Aquí se aplica una regla general que dice: si no está explícitamente permitido por las reglas anteriores, entonces se bloquea automáticamente. Es como decir “solo lo que está en la lista blanca pasa”.

¿Cómo? Se configura una regla final que deniegue todo el tráfico no especificado previamente.

- Registrar todos los accesos, sobre todo los fallidos:
Esto implica que el cortafuegos debe guardar registros (logs) de todas las conexiones que intenta manejar, con especial atención a las que se rechazan o fallan, ya que pueden indicar intentos de intrusión o errores de configuración.
¿Cómo? Se habilita la función de registro en el cortafuegos y se configuran alertas o revisiones periódicas de estos logs.

Además, la red estará dividida en zonas:

- Usuarios con acceso limitado.
- Servidores con datos críticos.
- Servicios en la nube con controles especiales.
- Zona DMZ para servicios públicos.

Esto ayuda a proteger mejor la información importante.

4. Sistema de Detección o Monitoreo de Accesos Sospechosos

Integraremos un sistema SIEM (como Wazuh o Splunk) junto con herramientas IDS/IPS (como Snort o Suricata). El SIEM se encargará de recopilar y analizar en tiempo real todos los registros y eventos generados por dispositivos de red, servidores y aplicaciones, facilitando la identificación rápida de patrones inusuales o amenazas emergentes. Por su parte, los sistemas IDS (Sistemas de Detección de Intrusos) y IPS (Sistemas de Prevención de Intrusos) monitorizan el tráfico de red para detectar ataques conocidos o comportamientos sospechosos; además, el IPS puede actuar bloqueando automáticamente las amenazas antes de que causen daño.

Un ejemplo típico de alerta podría ser cuando un usuario intenta acceder al sistema fuera de su horario habitual, desde una ubicación geográfica no autorizada, y realiza varios intentos fallidos de autenticación. Ante esta situación, el SIEM generará una alerta inmediata que notificará al equipo de seguridad para que investigue y tome acciones preventivas, como bloquear temporalmente la cuenta o reforzar la autenticación.

Esta combinación de tecnologías ofrece una defensa proactiva y reactiva, mejorando la visibilidad y capacidad de respuesta frente a posibles incidentes de seguridad.

5. Conclusión Técnica

Los CIS Controls v8 no son solo recomendaciones, sino una guía confiable para fortalecer la seguridad real en cualquier organización. Ayudan a reducir riesgos y a responder rápido ante incidentes.

Claro que hay retos: resistencia al cambio, costos y complejidad técnica para implementar todo. Por eso es fundamental mantener una mejora continua, con auditorías regulares, actualizaciones constantes y pruebas de penetración para validar que todo funcione bien.

Control CIS v8	Descripción breve
4.1	Configurar de forma segura routers, switches y cortafuegos, deshabilitando servicios y puertos innecesarios.
6.3	Proteger y monitorear las cuentas con privilegios administrativos para evitar accesos no autorizados.
7.1	Mantener un inventario actualizado del software autorizado para prevenir la instalación de programas maliciosos.
8.7	Implementar sistemas SIEM para centralizar el monitoreo y análisis de eventos de seguridad en tiempo real.
12.4	Escanear y corregir vulnerabilidades de forma periódica para reducir riesgos de explotación.
13.1	Dividir la red en segmentos o zonas para limitar el movimiento lateral de atacantes y proteger datos sensibles.